

CYBERSECURITY ASSESSMENT REPORT

AWS-Based FinTech Platform (Simulated Environment)

1. Executive Summary

This report looks at a simulated FinTech system hosted on AWS, built to represent a real financial cloud environment with a large user base (~1.5 million monthly users). The main goal was to identify realistic security issues, especially the kinds that actually show up in cloud breaches, and then map them to NIST CSF 2.0 and PCI-DSS v4.0.

What became pretty clear during the assessment is that most of the risk doesn't come from advanced attacks, but from basic configuration issues — especially IAM misconfigurations, exposed storage, and inconsistent logging.

This lines up with what research shows about real-world cloud security incidents, where misconfigurations are still one of the main root causes ([link-https://papers.ssrn.com/sol3/papers.cfm?abstract_id=6002874](https://papers.ssrn.com/sol3/papers.cfm?abstract_id=6002874)).

Overall, the environment ends up in a **high-risk category**, mainly because identity and access controls are not tightly enforced.

2. Scope and System Overview

The system is a pretty standard AWS-based setup:

- Web/API layer behind load balancers
- Application layer running on EC2
- Data layer using RDS and S3
- IAM used for identity and access control
- Remote endpoints for admin/ops access

Since this is a FinTech-style system, it naturally falls under PCI scope because it handles financial and card-related data.

Main assets considered:

- Customer PII
- Financial transactions
- Authentication credentials
- Cardholder data (PCI-related environment)

3. Methodology

The assessment wasn't based on just one model — it combines a few:

- STRIDE for threat categorisation
- AWS misconfiguration patterns from real-world cloud issues
- 5×5 risk matrix (likelihood × impact)
- NIST CSF 2.0 for control mapping
- PCI-DSS v4.0 for compliance alignment

Risk scoring is basically qualitative, but it's grounded in how often these issues actually appear in cloud environments. For example, IAM misconfigurations and public S3 buckets are consistently reported in real breach cases, so they are treated as high likelihood in this model.

This kind of hybrid approach is pretty common in cloud risk research ([link-https://scholar.google.com/scholar?q=cybersecurity+risk+assessment+cloud+quantitative+model](https://scholar.google.com/scholar?q=cybersecurity+risk+assessment+cloud+quantitative+model)).

4. Literature Context

Most cloud security research agrees on one thing: the majority of cloud breaches aren't due to sophisticated hacking — they're due to misconfigurations.

Things like:

- open storage buckets
- overly permissive IAM roles
- weak identity controls

These show up again and again in AWS environments.

There's also research showing that traditional threat models don't fully capture cloud complexity, which is why approaches like attack graphs and model-driven security analysis are used ([link-https://www.researchgate.net/publication/400546644_Threat_Modeling_for_AI-Powered_Financial_Applications_on_AWS](https://www.researchgate.net/publication/400546644_Threat_Modeling_for_AI-Powered_Financial_Applications_on_AWS)).

5. Threat Modeling (STRIDE + AWS context)

From a threat point of view, the system is exposed mainly through identity and configuration weaknesses.

Main realistic threats include:

- Credential theft leading to full account access
- Public S3 buckets exposing sensitive data
- Over-permissioned IAM roles (privilege escalation risk)
- Exposed EC2 ports (SSH/RDP)
- API abuse through weak authentication

Cloud systems make this worse because everything is connected — one small IAM issue can quickly turn into full system compromise.

Research on AWS environments shows the same pattern repeatedly, especially around IAM and S3 misconfigurations (*link- <https://doi.org/10.9734/jerr/2025/v27i31442>*).

6. Architecture Observations

The architecture itself is fairly standard for a FinTech cloud system, but the security enforcement looks a bit uneven.

Some key observations:

- Network segmentation exists but isn't strictly enforced everywhere
- IAM permissions look broader than they should be
- Logging is not consistently applied across services
- Encryption is assumed in some areas but not clearly enforced end-to-end

In real cloud environments, this kind of “partially implemented security” is usually where problems start.

7. Security Findings

F-01: Public S3 Exposure

Some storage resources appear to be publicly accessible or not properly locked down. This directly risks data leakage.

F-02: Over-permissive IAM roles

IAM policies allow overly broad permissions, which increases impact if credentials are compromised.

F-03: Missing MFA for privileged accounts

Admin accounts without MFA significantly increase takeover risk.

F-04: Incomplete logging

Logging isn't fully enabled across all services, which reduces visibility during incidents.

F-05: Open security groups

Some inbound rules are too open, increasing exposure to external attacks.

Misconfigurations like these are still one of the biggest causes of cloud breaches in real systems (link- https://papers.ssrn.com/sol3/papers.cfm?abstract_id=5146568).

8. Risk Register (5×5)

ID	Risk	Likelihood	Impact	Score	Level
R1	IAM privilege escalation	5	5	25	Critical
R2	Public S3 exposure	5	5	25	Critical
R3	Missing MFA	4	5	20	Critical
R4	Open security groups	4	4	16	High
R5	Logging gaps	3	5	15	High

This scoring approach is consistent with standard cloud risk modelling methods used in cybersecurity research (link- <https://scholar.google.com/scholar?q=5x5+risk+matrix+cybersecurity+quantitative+model>) .

9. Control Mapping (NIST + PCI-DSS)

Issue	NIST CSF	PCI-DSS	Control Action
S3 exposure	Protect	Req 3	Block public access
IAM issues	Protect	Req 8	Least privilege enforcement
Logging gaps	Detect	Req 10	Enable centralized logging
Network exposure	Protect	Req 1	Restrict inbound rules

NIST CSF is widely used in cloud governance because it helps map technical issues to structured security functions (link- <https://www.nist.gov/cyberframework>).

10. Monitoring

In a real setup, you'd expect something like:

- CloudTrail for logs
- GuardDuty for threat detection
- SIEM system for correlation

Without proper monitoring, most of these issues would likely go unnoticed until after a breach.

11. Remediation Plan

First 30 days:

- Enforce MFA everywhere
- Remove public S3 access
- Fix wildcard IAM permissions

30–60 days:

- Improve logging coverage
- Tighten network rules
- Segment VPC more strictly

60–90 days:

- Move toward Zero Trust IAM model
 - Automate compliance checks
 - Add continuous monitoring
-

12. Conclusion

The biggest issue here isn't one specific vulnerability — it's a combination of identity misconfiguration and inconsistent security enforcement.

This is actually very similar to real-world cloud incidents in FinTech systems, where most breaches happen because of basic misconfigurations rather than advanced exploits.

Fixing IAM and enforcing consistent configuration standards would significantly reduce overall risk.

REFERENCES

- <https://www.nist.gov/cyberframework>
- https://papers.ssrn.com/sol3/papers.cfm?abstract_id=5146568
- https://papers.ssrn.com/sol3/papers.cfm?abstract_id=6002874
- <https://doi.org/10.9734/jerr/2025/v27i31442>
- https://www.researchgate.net/publication/400546644_Threat_Modeling_for_AI-Powered_Financial_Applications_on_AWS
- <https://scholar.google.com/scholar?q=cybersecurity+risk+assessment+cloud+quantitative+model>